

KRİPTOQRAFIYA KURSU

Mühazirə 11: Blok Şifrələrin İş Rejimləri

Ətraflı mühazirə qeydləri

Həftə 11: ECB, CBC, CFB, OFB, CTR, GCM, CCM, XTS

June 26, 2026

Contents

1 Giriş	3
2 Məlumatın Doldurulması (Padding)	3
2.1 PKCS#7 Standartı	3
2.2 Padding Oracle Hücumu	4
3 ECB Rejimi (Electronic Codebook)	4
3.1 ECB Rejiminin Xüsusiyyətləri	4
3.2 ECB Rejiminin Problemləri	5
4 CBC Rejimi (Cipher Block Chaining)	5
4.1 IV (İlkin Vektor) və Təhlükəsizlik	6
4.2 Məlumatın Doldurulması (Padding)	6
4.3 Xüsusiyyətlər: Paralelləşdirmə və Xəta	6
5 CFB Rejimi (Cipher Feedback)	7
5.1 Deşifrləmənin Xüsusiyyəti	7
5.2 CFB Rejiminin Xüsusiyyətləri	7
5.3 s Parametrinin Seçimi	8
6 OFB Rejimi (Output Feedback)	8
6.1 OFB Rejiminin Xüsusiyyətləri	8
6.2 CFB və OFB Müqayisəsi	9
7 CTR Rejimi (Sayğac rejimi, Counter Mode)	9
7.1 CTR Rejiminin Üstünlükləri	9
7.2 Sayğacın Dizaynı (Counter Structure)	10
7.3 Performans: Intel AES-NI və Paralelləşmə	10
8 AEAD Rejimleri (Əlavə Məlumatlı Avtəntikləşdirilmiş Şifrələmə - Authenticated Encryption with Associated Data)	10
8.1 GCM (Qalua/Sayğac rejimi - Galois/Counter Mode)	11
8.2 CCM (CBC-MAC ilə Sayğac - Counter with CBC-MAC)	11
8.3 GCM-SIV: Nonce düzgün istifadə edilməməsinə müqavimət - Nonce-Misuse Resistance	12
8.4 GCM və CCM Müqayisəli Analizi	12
9 XTS Rejimi (XEX-based Tweaked CodeBook)	13
9.1 XTS Rejiminin Xüsusiyyətləri	13
9.2 İş Rejimlərinin Xülasə Müqayisəsi	14
10 Praktiki Təvsiyələr	14
10.1 Hansı Rejimi Seçməli?	14
10.2 IV və Nonce İdarəedilməsi	15

11 Praktiki Tapşırıqlar	15
11.1 Tapşırıq 1: ECB Problemi (Vizual Analiz)	15
11.2 Tapşırıq 2: CBC Şifrləmənin Addımları	15
11.3 Tapşırıq 3: CTR Rejimində Sayğacın Generasiyası	16
11.4 Tapşırıq 4: GCM və Əlaqəli Verilənlər (AD)	16
11.5 Tapşırıq 5: XTS Tweak Hesablanması	16
11.6 Tapşırıq 6: Python-da Rejimlərin Implementasiyası	16
11.7 Tapşırıq 7: Padding Oracle Hücumu Simulyasiyası	16
12 Nəticə	17
13 Praktiki Tapşırıqlar: Model Cavablar	18
13.1 Cavab 1: ECB Problemi	18
13.2 Cavab 2: CBC Şifrləmə Prosesi	18
13.3 Cavab 3: CTR Sayğac Dəyərləri	18
13.4 Cavab 4: GCM-də AD-nin (Əlaqəli Verilənlər) Rolu	19
13.5 Cavab 5: XTS Tweak Hesablanması	19
13.6 Cavab 7: Padding Oracle Hücumu	19

1 Giriş

Əvvəlki mühazirələrdə blok şifrələrin özlərini öyrəndik — AES, DES kimi alqoritmlər tək bir bloku (128-bit və ya 64-bit) şifrəyir. Lakin real dünyada mesajlar ixtiyari uzunluqda olur. Blok şifrələri ixtiyari uzunluqlu mesajlara tətbiq etmək üçün **iş rejimləri** (modes of operation) istifadə olunur (Dworkin, 2001; Bellare et al., 1997).

Bu mühazirədə aşağıdakı iş rejimlərini ətraflı öyrənəcəyik:

- **ECB (Electronic Codebook)** — Elektron Kod Kitabı
- **CBC (Cipher Block Chaining)** — Şifrə Bloklarının Zəncirlənməsi
- **CFB (Cipher Feedback)** — Şifrə Əks-Əlaqəsi
- **OFB (Output Feedback)** — Çıxış Əks-Əlaqəsi
- **CTR (Counter)** — Sayğac Rejimi
- **GCM (Galois/Counter Mode)** — Qalua/Sayğac Rejimi (AEAD)
- **CCM (Counter with CBC-MAC)** — Sayğac + CBC-MAC (AEAD)
- **XTS (XEX-based Tweaked CodeBook)** — Disk şifrələməsi üçün

Niyə iş rejimləri lazımdır?

Blok şifrələr tək bir bloku şifrəyir. Uzun mesajlar üçün:

1. Mesaj bloklara bölünməlidir;
2. Hər blok şifrənməlidir;
3. Eyni açıq mətn blokları eyni şifrəli mətn blokları verməməlidir (*Pattern hiding*);
4. Şifrələmə eyni açarla eyni mesajda təhlükəsiz olmalıdır.

İş rejimləri bu problemləri həll edir (Rogaway, 2011).

2 Məlumatın Doldurulması (Padding)

Blok şifrələr (məsələn, AES) sabit blok ölçüsü ($L = 16$ bayt) ilə işləyir. Lakin real mesajların uzunluğu həmişə blok ölçüsünün tam mislləri olmur. Bu halda sonuncu bloku tamamlamaq üçün **Padding** metodlarından istifadə olunur (Dworkin, 2001).

2.1 PKCS#7 Standartı

Ən geniş yayılmış doldurma üsulu PKCS#7-dir. Bu metodda çatışmayan baytların sayı qədər bayt əlavə edilir və hər bir əlavə edilən baytın dəyəri məhz həmin saya bərabər olur.

PKCS#7 Hesablanması

Əgər blokun dolması üçün N sayda bayt çatışmırsa, blokun sonuna N dəfə $0xN$ dəyəri əlavə edilir.

- 1 bayt çatışmırsa: ... | 01
- 3 bayt çatışmırsa: ... | 03 03 03
- Blok tamdırsa: Bu halda **tam bir blok** (16 bayt) əlavə edilir (10 10 ... 10), beləliklə deşifrəlmə zamanı sonun harada bitdiyi qarışdırılır.

2.2 Padding Oracle Hücumu

Padding-in düzgün tətbiqi həm də təhlükəsizlik məsələsidir.

Padding Oracle Attack

Əgər server deşifrəlmə zamanı padding-in səhv olub-olmaması barədə xəta mesajı qaytararsa (məsələn, "Invalid Padding"), hücumçu bu məlumatdan istifadə edərək şifrəli mətni blok-blok deşifrəyə bilər (Jager and Somorovsky, 2011). Bu səbəbdən müasir sistemlərdə padding-i yoxlamazdan əvvəl mesajın tamlığı (MAC vasitəsilə) yoxlanmalıdır.

3 ECB Rejimi (Electronic Codebook)

ECB ən sadə iş rejimidir. Mesaj bloklara bölünür və hər blok digərlərindən tamamilə müstəqil şəkildə şifrlənir (Dworkin, 2001).

ECB Şifrləmə

Şifrləmə tənliyi:

$$C_i = E_K(P_i)$$

Deşifrəlmə tənliyi:

$$P_i = D_K(C_i)$$

burada P_i açıq mətn bloku, C_i şifrəli mətn bloku, E_K isə açarla idarə olunan blok şifrə funksiyasıdır.

3.1 ECB Rejiminin Xüsusiyyətləri

- **Sadəlik:** Rejimin tətbiqi və başa düşülməsi çox asandır.
- **Paraleللəşdirmə:** Hər bir blok müstəqil olduğu üçün şifrləmə və deşifrəlmə eyni anda bir neçə prosessor nüvəsində (*multithreading*) həyata keçirilə bilər.
- **Təsadüfi Giriş (Random Access):** Mesajın ortasındakı bir bloku oxumaq üçün əvvəlki blokları deşifrəlməyə ehtiyac yoxdur.

3.2 ECB Rejiminin Problemləri

ECB-nin Əsas Zəifliyi

Eyni açıq mətn blokları eyni açarla həmişə eyni şifrəli mətn bloklarını yaradır. Bu, şifrəli mətnə daxili statistik quruluşun (*pattern*) qalmasına və məlumat sızmasına səbəb olur (Stallings, 2017).

ECB Nümunəsi — "Linux" Pinqvini

Linux maskotu olan Tux şəkli ECB rejimində şifrələndikdə, rəng dəyərləri dəyişsə də, eyni rəngli piksellər eyni şifrəli dəyərləri verdiyi üçün orijinal şəklın konturları aydın şəkildə görünməyə davam edir (Paar and Pelzl, 2010).

BLOK ŞİFRƏLƏRİN İŞ REJİMLƏRİNİN VİZUAL NÜMAYİŞİ: 'AES PINQVİNİ' EFEKTİ

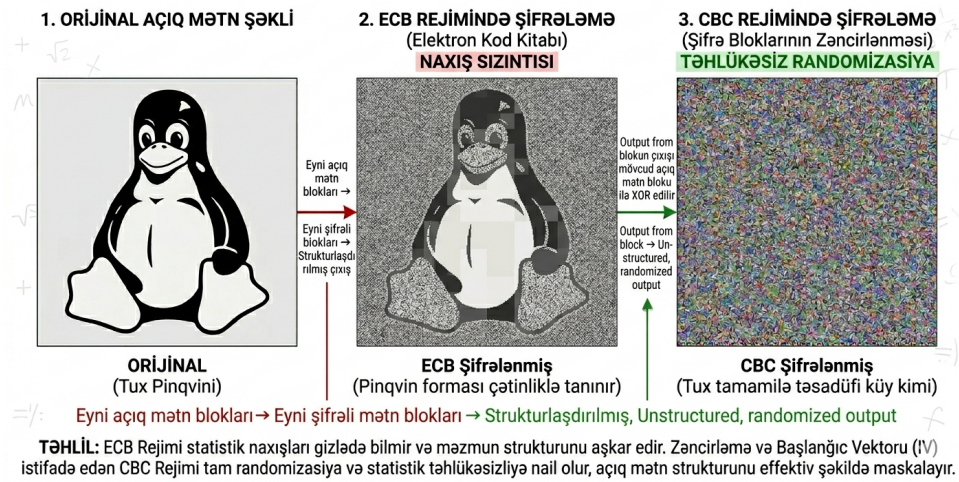


Figure 1: ECB və digər təhlükəsiz rejimlərin müqayisəsi: ECB rejimində şifrələnmiş şəkildə statistik naxışların sızması aydın görünür (pinqvinin forması tanınır), CBC rejimində isə məlumat tamamilə randomizə olunub.

ECB Nə Vaxt İstifadə Oluna Bilər?

ECB müasir təhlükəsizlik tələblərinə cavab vermir və ümumiyyətlə istifadəsi tövsiyə edilmir (Dworkin, 2001). Yalnız tamamilə təsadüfi paylanmış kiçik məlumatların (məsələn, digər şifrələmə açarlarının) şifrələnməsi üçün tətbiq oluna bilər.

4 CBC Rejimi (Cipher Block Chaining)

CBC rejimində hər bir açıq mətn bloku şifrələnmədən əvvəl əvvəlki şifrəli mətn bloku ilə XOR əməliyyatına məruz qalır (Dworkin, 2001). Bu zəncirvari struktur eyni açıq mətn bloklarının fərqli şifrəli bloklara çevrilməsini təmin edərək naxış sızıntısını (pattern leakage) aradan qaldırır.

CBC Riyazi Mexanizmi**Şifrləmə:**

$$C_i = E_K(P_i \oplus C_{i-1})$$

Burada $C_0 = IV$ (İlkin Vektor).

Deşifrləmə:

$$P_i = D_K(C_i) \oplus C_{i-1}$$

Burada $P_1 = D_K(C_1) \oplus IV$.

4.1 IV (İlkin Vektor) və Təhlükəsizlik

IV şifrləmənin deterministik olmamasını təmin edir. Əsas tələblər:

- **Unikallıq:** Eyni açarla eyni IV heç vaxt təkrar istifadə edilməməlidir.
- **Təsadüfilik:** IV təxmin edilə bilməz olmalıdır. Proqnozlaşdırıla bilən IV-lər (məsələn, ardıcıl saylar) *chosen-plaintext* hücumlarına yol açır.

IV Təkrarı və Hücumlar

IV-nin təkrarı və ya zəif seçilməsi (Rogaway, 2011) nəticəsində hücumçu mesajların pre-fikslərinin eyni olub-olmadığını öyrənə bilər. CBC rejimi həmçinin **Padding Oracle** hücumuna qarşı həssasdır (Jager and Somorovsky, 2011; Rogaway et al., 2001), burada hücumçu padding xətlərindən istifadə edərək mesajı bayt-bayt bərpa edir.

4.2 Məlumatın Doldurulması (Padding)

CBC blok-əsaslı rejim olduğu üçün mesajın uzunluğu blok ölçüsünün ($L = 16$ bayt) misli olmalıdır.

- **PKCS#7:** Ən çox istifadə olunan doldurma metodudur. Çatışmayan N bayt qədər N dəyəri əlavə edilir.
- **Tam blok halı:** Əgər mesaj tamdırsa, əlavə bir tam blok (16 baytlıq 0×10) əlavə edilir ki, deşifrləmə zamanı qarışıqlıq yaranmasın.

4.3 Xüsusiyyətlər: Paralelləşdirmə və Xəta

- **Şifrləmə:** Paralelləşdirilə bilməz (C_i üçün C_{i-1} lazımdır).
- **Deşifrləmə:** Tamamilə paralelləşdirilə bilər, çünki bütün C blokları öncədən məlumdur.
- **Xəta Yayılması:** C_i blokundakı 1 bitlik xəta P_i -ni tamamilə korlayır, lakin P_{i+1} -də yalnız müvafiq 1 bitlik xətəyə səbəb olur (XOR xüsusiyyəti).

CBC Hesablanması (8-bit Sadələşmiş)

Açar K və $IV = 0x12$ verilib. $P_1 = 0x53$ ('S') şifrəliyək:

1. XOR mərhələsi: $P_1 \oplus IV = 0x53 \oplus 0x12 = 0x41$
2. Şifrəlmə: $C_1 = E_K(0x41)$
3. Növbəti blok üçün C_1 yeni "zəncir" halqası olur.

5 CFB Rejimi (Cipher Feedback)

CFB rejimi blok şifrəni effektiv şəkildə **axın şifrəsinə (stream cipher)** çevirir. Bu rejimdə açıq mətn birbaşa blok şifrə alqoritminə (məs. AES) daxil olmur. Bunun əvəzinə, blok şifrə unikal bir **açar axını (keystream)** yaradır və bu axın açıq mətnlə XOR edilir (Dworkin, 2001).

CFB Riyazi Mexanizmi

CFB rejimi s -bitlik seqmentlərlə işləyir. Hər addımda b -bitlik sürüşmə registri (I) istifadə olunur:

$$\begin{aligned} I_1 &= IV \\ O_j &= E_K(I_j) \\ C_j &= P_j \oplus \text{MSB}_s(O_j) \\ I_{j+1} &= \text{LSB}_{b-s}(I_j) \parallel C_j \end{aligned}$$

Burada MSB_s çıxışın ilk s bitini, LSB_{b-s} isə sürüşmə registrinin son $b - s$ bitini ifadə edir. $\parallel$ işarəsi isə bitlərin zəncirlənməsini (concatenation) göstərir.

5.1 Deşifrləmənin Xüsusiyyəti

CFB-nin ən maraqlı cəhəti odur ki, deşifrləmə zamanı da blok şifrənin **şifrəlmə (Encryption)** funksiyası istifadə olunur:

$$P_j = C_j \oplus \text{MSB}_s(E_K(I_j))$$

Bunun səbəbi şifrəlmə zamanı istifadə olunan "açar axını" eynilə bərpa etmək zərurətidir.

5.2 CFB Rejiminin Xüsusiyyətləri

- **Doldurma (Padding) Tələb Etmir:** Mesajın uzunluğu blok ölçüsünün misli olmaq məcburiyyətində deyil. İxtiyari bit uzunluğunda mesajlar şifrələ bilər.
- **Sinxronizasiya:** CFB-nin özünübərpa xüsusiyyəti var. Əgər ötürmə zamanı bəzi bitlər itərsə və ya əlavə olunarsa, sürüşmə registri tam dolduqdan sonra sistem yenidən düzgün deşifrləməyə başlayır.
- **Paralelləşdirmə:** Şifrəlmə ardıcıl (sequential) aparılmalıdır, lakin deşifrləmə paralelləşdirilə bilər (çünki C_j blokları artıq əlimizdədir).

5.3 s Parametrinin Seçimi

CFB rejimi s parametrindən asılı olaraq çevikdir:

Rejim	Tətbiq Sahəsi
CFB-1	Bit səviyyəli ötürmə (hər bit üçün bir AES əməliyyatı - çox yavaş)
CFB-8	Simvol səviyyəli ötürmə (Terminal emulyasiyaları)
CFB-128	Tam blok səviyyəli (AES üçün maksimum səmərəlilik)

Table 1: CFB-də s parametrinin müxtəlif dəyərləri.

CFB və Xəta Yayılması

Şifrəli mətdəki (C_j) bir bitlik xəta həm cari P_j blokunu korlayır, həm də sürüşmə reqistri vasitəsilə növbəti bloklara təsir edir. Sürüşmə reqistrindən həmin xətalı bit çıxdıqdan sonra deşifrəlmə avtomatik düzəlir (Stallings, 2017).

6 OFB Rejimi (Output Feedback)

OFB rejimi də blok şifrəni axın şifrəsinə çevirir. CFB-dən əsas fərqi ondan ibarətdir ki, burada geri-əlaqə (feedback) şifrəli mətdən deyil, birbaşa blok şifrənin öz çıxışından (output) götürülür (Dworkin, 2001). Bu o deməkdir ki, açar axını (keystream) açıq mətdən tamamilə müstəqil şəkildə formalaşır.

OFB Şifrəlmə və Deşifrəlmə

Şifrəlmə prosesi unikal bir açar axını (O_i) yaradılmasına əsaslanır:

$$\begin{aligned}
 O_0 &= IV \\
 O_i &= E_K(O_{i-1}) \quad (\text{Açar axını}) \\
 C_i &= P_i \oplus O_i \quad (\text{Şifrəlmə}) \\
 P_i &= C_i \oplus O_i \quad (\text{Deşifrəlmə})
 \end{aligned}$$

Burada E_K yalnız şifrəlmə rejimində istifadə olunur (həm şifrəlmə, həm də deşifrəlmə zamanı).

6.1 OFB Rejiminin Xüsusiyyətləri

- **Axın Şifrəsi Mexanizmi:** Məlumat blok ölçüsündən asılı olmayaraq bit-bit və ya bayt-bayt şifrənlənə bilər, buna görə də *padding* (doldurma) tələb olunmur.
- **Əvvəlcədən Hesablama (Offline Processing):** Açar axını (O_i) açıq mətn hələ hazır olmadan belə əvvəlcədən hesablanı bilər. Bu, real zamanlı sistemlərdə yüksək sürət təmin edir.
- **Xəta Yayılmasının Olmaması:** Şifrəli mətdəki (C_i) bir bitlik xəta deşifrəlmə zamanı yalnız müvafiq açıq mətn bitini (P_i) korlayır. Bu, səs və video ötürülməsi kimi xətalara qarşı dözümlü sistemlər üçün idealdır.

- **Sinxronizasiya Həssaslığı:** Əgər ötürmə zamanı bir bit itərsə və ya əlavə olunarsa, bütün növbəti bloklar yanlış deşifrlənəcək (sinxronizasiya itir).

Açar Axımının Təkrarı Təhlükəsi

Əgər eyni (K, IV) cütünü iki fərqli mesaj üçün istifadə olunarsa, eyni açar axını yaranacaq. Hücümçü iki şifrəli mətni XOR edərək açıq mətnlər haqqında məlumat əldə edə bilər ($C_1 \oplus C_2 = P_1 \oplus P_2$) (Paar and Pelzl, 2010).

6.2 CFB və OFB Müqayisəsi

Table 2: CFB və OFB rejimlərinin müqayisəli təhlili

Xüsusiyyət	CFB	OFB
Geri-əlaqə mənbəyi	Şifrəli mətn (C_i)	Çıxış (O_i)
Xəta yayılması	Cari blok + Növbəti blok	Yalnız cari bit
Özünü-sinxronizasiya	Məhdud (Bəli)	Xeyr
Offline hesablama	Mümkün deyil	Mümkündür
Tip	Blok şifrə əsaslı axın	Təmiz axın şifrəsi

7 CTR Rejimi (Sayğac rejimi, Counter Mode)

CTR rejimi blok şifrəni yüksək performanslı axın şifrəsinə çevirir. Bu rejimdə şifrəlmə alqoritmi birbaşa açıq mətn bloklarını deyil, unikal bir **sayğac (counter)** dəyərlərini şifrələyir. Yaranan açar axını (keystream) daha sonra açıq mətnlə XOR edilir (Dworkin, 2001).

CTR Riyazi Mexanizmi

Hər bir blok üçün müstəqil olaraq aşağıdakı əməliyyat yerinə yetirilir:

$$O_i = E_K(CTR_i) \quad (\text{Açar axını})$$

$$C_i = P_i \oplus O_i \quad (\text{Şifrəlmə})$$

$$P_i = C_i \oplus O_i \quad (\text{Deşifrləmə})$$

Burada CTR_i unikal blokdur. Adətən $CTR_i = \text{Nonce} \parallel \text{Sayğac}$ formatında təşkil olunur.

7.1 CTR Rejiminin Üstünlükləri

CTR rejimi OFB-nin bütün üstünlüklərini saxlayır, lakin onun əsas çatışmazlığını (paralelləşdirmə problemini) həll edir:

- **Tam Paralelləşdirmə:** Hər bir blokun şifrəlməsi və deşifrlənməsi digərindən tamamilə müstəqildir. Bu, müasir çoxnüvəli prosessorlarda maksimum sürət deməkdir.
- **Təsadüfi Giriş (Random Access):** Böyük bir faylın ortasındakı məlumatı deşifrləmək üçün əvvəlki blokları deşifrləməyə ehtiyac yoxdur.

- **Doldurma (Padding) Tələb Etmir:** Mesajın uzunluğu blok ölçüsünə uyğun gəlməyə bilər, çünki o, axın şifrəsi kimi davranır.
- **Hardware Effektivliyi:** Şifrələmə və deşifrələmə eyni E_K dövrəsindən istifadə edir ki, bu da çiplərin sahəsinə qənaət edir.

7.2 Sayğacın Dizaynı (Counter Structure)

Sayğac bloku adətən 128 bit (AES üçün) olur və iki hissəyə bölünür:

1. **Nonce (64-bit):** Hər mesaj üçün unikal olan təsadüfi ədəd.
2. **Counter (64-bit):** Hər blokda bir vahid artırılan hissə.

Sayğacın Təkrarı (Catastrophic Failure)

Əgər eyni (K, CTR) cütlüyü fərqli mesajlar üçün təkrar istifadə olunarsa (məsələn, sistem yenidən başladıldıqda eyni sayğacdən başlayarsa), iki şifrəli mətnin XOR-u açıq mətnlərin XOR-una bərabər olur ($C_1 \oplus C_2 = P_1 \oplus P_2$). Bu, Two-Time Pad hücumuna yol açır.

7.3 Performans: Intel AES-NI və Paralelləşmə

Müasir CPU-larda mövcud olan AES-NI (Advanced Encryption Standard New Instructions) təlimatları eyni anda bir neçə AES əməliyyatını emal edə bilər. CTR rejimi bloklar arasında asılılıq yaratmadığı üçün AES-NI ilə birlikdə istifadə edildikdə saniyədə bir neçə qiqabit (Gbps) sürətlə şifrələmə təmin edir (Paar and Pelzl, 2010).

8 AEAD Rejimləri (Əlavə Məlumatlı Avtentikləşdirilmiş Şifrələmə - Authenticated Encryption with Associated Data)

AEAD rejimləri müasir kriptografiyanın "qızıl standartı" hesab olunur, çünki onlar eyni zamanda həm məxfiliyi (şifrələmə), həm də tamlığı və autentifikasiyanı (teq) təmin edir (Rogaway et al., 2001).

AEAD-in Komponentləri

AEAD rejimi üç giriş məlumatı əsasında işləyir:

- **Açıq mətn (P):** Şifrələnəcək əsas gizli məlumat.
- **Əlavə Məlumat - Associated Data (AD):** Şifrəlməyən (məsələn, IP paket başlığı), lakin tamlığı qorunmalı olan məlumatlar.
- **Açar (K) və Nonce (N):** Unikallığı təmin edən parametrlər.

Çıxış: Şifrəli mətn (C) + Autentifikasiya teqi (T).

8.1 GCM (Qalua/Sayğac rejimi - Galois/Counter Mode)

GCM hazırda müasir kriptografiyanın "qızıl standartı" və dünyada ən çox istifadə olunan AEAD rejimidir. O, məlumatın məxfiliyini təmin etmək üçün CTR rejimini, tamlığını və həqiqiliyini yoxlamaq üçün isə Qalua meydanında ($GF(2^{128})$) hesablanan GHASH funksiyasını birləşdirir (Dworkin, 2007).

GCM-in İş Prinsipi: Şifrələmə və Autentifikasiya

GCM eyni vaxtda iki növ məlumatı emal edir:

- **Açıq mətn - Plain text (P):** Həm şifrlənir, həm də autentifikasiya olunur (məsələn, mesajın mətni).
- **Əlaqəli data - Associated Data (AD):** Şifrlənmir (açıq qalır), lakin **autentifikasiya olunur**. Bu, şəbəkə protokollarında (məs. IP başlıqları) IP ünvanların və ya portların yolda dəyişdirilməsinin qarşısını almaq üçün kritikdir.

- **Effektivlik:** GCM tam paralelləşdirilə bilən bir struktura malikdir. Həm CTR şifrələməsi, həm də GHASH hesabı bir-birindən asılı olmadan aparıla bildiyi üçün çox yüksək ötürmə sürəti (Gbps+) təmin edir.
- **Təhlükəsizlik:** Əgər haker şifrəli mətni (C) və ya açıq qalan AD hissəsini bircə bit belə dəyişdirsə, hesablanan autentifikasiya teqi (T) orijinal teqlə uyğun gəlməyəcək və sistem paketi saxta hesab edərək dərhal rədd edəcək.

GCM-in Real Dünyada Tətbiqi

Müasir internet təhlükəsizliyi demək olar ki, tamamilə GCM üzərində qurulub:

- **TLS 1.3:** HTTPS bağlantılarında ən təhlükəsiz və sürətli seçim olaraq AES_128_GCM istifadə edir.
- **VPN və IPsec:** Şəbəkə paketlərinin başlıqlarını (AD olaraq) qorumaq və məzmununu şifrləmək üçün ən ideal rejimdir.

Kritik Qeyd: Nonce Təkrarı

GCM rejimində eyni açar ilə eyni Nonce-un (IV) təkrar istifadəsi fəlakətlə nəticələnir. Bu halda hücumçu həm açar axını, həm də GHASH autentifikasiya açarını əldə edə bilər ki, bu da sistemin tamamilə çökməsi deməkdir.

8.2 CCM (CBC-MAC ilə Sayğac - Counter with CBC-MAC)

CCM rejimi adından da göründüyü kimi, məxfiliyi təmin etmək üçün CTR rejimini, tamlığı yoxlamaq üçün isə CBC-MAC metodunu birləşdirir (Dworkin, 2004). GCM-dən əsas fərqi, onun "iki-keçidli" (two-pass) bir alqoritm olmasıdır.

- **Üstünlüyü:** Riyazi strukturu GCM-ə nisbətən daha sadədir və mürəkkəb Qalua meydanı hesablamaları tələb etmir. Həmçinin, heç bir patent məhdudiyyəti olmadan sərbəst istifadə edilə bilər.

- **Çatışmazlığı:** Şifrələmə başlamazdan əvvəl mesajın tam uzunluğu məlum olmalıdır (bu, axınlı videolar üçün problem yarada bilər). Bundan əlavə, ardıcıl (sequential) işlədiyi üçün GCM qədər sürətli deyil.
- **Tətbiq sahələri:** Hesablama gücü məhdud olan cihazlarda və simsiz şəbəkə standartlarında geniş istifadə olunur:
 - **IEEE 802.11i (WPA2):** Wi-Fi təhlükəsizliyinin əsasını təşkil edir.
 - **Bluetooth:** Məlumatların qorunması üçün istifadə edilir.
 - **ZigBee (IoT):** Enerji qənaətli sensor şəbəkələrində tətbiq olunur.

CCM vs GCM Seçimi

Əgər sisteminizdə aparat sürətləndiricisi (məsələn, Intel AES-NI) varsa və yüksək sürət lazımdırsa, **GCM** seçilməlidir. Əgər resurslar məhduddursa və ya patendlərdən qaçmaq istəyirsinizsə, **CCM** daha etibarlı seçimdir.

8.3 GCM-SIV: Nonce düzgün istifadə edilməməsinə müqavimət - Nonce-Misuse Resistance

GCM-in (və ümumiyyətlə CTR əsaslı rejimlərin) ən böyük zəifliyi eyni Nonce-un təkrarlanmasıdır (*Nonce-misuse*). Bu baş verdikdə açar axını (keystream) açılır və bütün məxfilik itir. RFC 8452 ilə təsvir olunan **GCM-SIV** (Sintetik başlanğıc qiyməti vektoru - Synthetic Initialization Vector) bu problemi riyazi üsulla həll edir.

- **Dayanıqlıq:** Nonce təkrarlansa belə, hücumçu açar axınını və ya GHASH açarını bərpa edə bilmir. Ən pis halda hücumçu yalnız iki eyni mesajın eyni olduğunu öyrənə bilər (deterministik şifrələmə kimi), lakin mesajın içeri oxuya bilməz.
- **İş prinsipi:** SIV (Sintetik IV) birbaşa mesajın özündən və nonce-dan törədilir. Yəni mesaj dəyişdikdə IV də avtomatik dəyişir, bu da sistemi proqramlaşdırma səhvlərinə qarşı müstəsna dərəcədə dayanıqlı edir.

8.4 GCM və CCM Müqayisəli Analizi

Bu iki AEAD rejimi müasir şəbəkə protokollarının sütunlarıdır, lakin fərqli ehtiyaclara xidmət edirlər.

Hansı seçməli?

Əgər aparat səviyyəsində AES sürətləndirməsi (AES-NI) mövcuddursa və saniyədə qıqabitlərlə məlumat ötürülərsə, **GCM** mütləq seçimdir. Lakin çox kiçik mikrokontrollerlərdə və ya patendlərdən tam sığortalanmaq lazım gəldikdə **CCM** daha çox üstünlük təşkil edir.

Table 3: GCM və CCM rejimlərinin texniki müqayisəsi

Xüsusiyyət	GCM (Qalua/Sayğac)	CCM (Sayğac və CBC-MAC)
Sürət	Çox yüksək (Paralel emal)	Orta (Ardıcıl emal)
Hesablama Metodu	Konveyerləşdirməyə uyğun / Aparat səviyyəsində optimal-laşdırılmış	İki-keçidli (Məlumat üzərindən iki dəfə keçilir)
Nonce Həssaslığı	Çox yüksək (Kritik dərəcədə həssas)	Yüksək
Tətbiq Sahəsi	TLS 1.3, Google/Meta serverləri, VPN	WPA2, Bluetooth, ZigBee (IoT - Əşyaların İnterneti)

9 XTS Rejimi (XEX-based Tweaked CodeBook)

XTS rejimi fərdi kompüterlərin və serverlərin yaddaş qurğularında (HDD/SSD) saxlanılan məlumatların şifrənməsi üçün xüsusi olaraq dizayn edilmişdir. Bu rejim IEEE 1619 standartı olaraq qəbul edilmişdir (Dworkin, 2010).

XTS Riyazi Mexanizmi

XTS iki fərqli açar (K_1, K_2) istifadə edir. Hər bir blok üçün unikal "tweak" (dəyişdirici) dəyəri hesablanır:

$$T_i = E_{K_2}(S) \otimes \alpha^{i-1}$$

$$C_i = E_{K_1}(P_i \oplus T_i) \oplus T_i$$

Burada S məlumat vahidinin (məsələn, sektorun) nömrəsini, α isə sonlu meydanda ($GF(2^{128})$) primitiv (generator) elementi ifadə edir.

9.1 XTS Rejiminin Xüsusiyyətləri

- **Tweak (Dəyişdirici):** Hər blok üçün sektor nömrəsinə əsaslanan fərqli "tweak" istifadə olunur. Bu, eyni açıq mətnin müxtəlif sektorlarda fərqli şifrələnməsini təmin edir.
- **Təsadüfi Giriş (Random Access):** İstənilən sektoru digərlərindən asılı olmadan, sürətli şəkildə şifrələmək və ya deşifrələmək mümkündür.
- **Məlumat Yayılması (Data Expansion):** XTS şifrələmə zamanı məlumatın ölçüsünü artırır, bu da disk sektorlarının sabit ölçüsü üçün kritikdir.

XTS-in Praktiki Tətbiqləri

XTS hazırda disk şifrəlmə proqram təminatlarında standartdır:

- **BitLocker** (Windows), **FileVault** (macOS)
- **LUKS** (Linux Disk Encryption)
- **VeraCrypt** (Açıq mənbəli şifrəlmə aləti)

9.2 İş Rejimlərinin Xülasə Müqayisəsi

Table 4: Bütün əsas iş rejimlərinin texniki müqayisəsi

Xüsusiyyət	ECB	CBC	CFB	OFB	CTR	GCM
Paralel Şifr.	Bəli	Xeyr	Xeyr	Xeyr	Bəli	Bəli
Paralel Deşifr.	Bəli	Bəli	Bəli	Xeyr	Bəli	Bəli
Təsadüfi Giriş	Bəli	Xeyr	Xeyr	Xeyr	Bəli	Bəli
Doldurma (Padding)	Bəli	Bəli	Xeyr	Xeyr	Xeyr	Xeyr
Xəta Yayılması	Yox	Blok+1	Blok+1	Yox	Yox	Yox
Tamliq (AEAD)	Xeyr	Xeyr	Xeyr	Xeyr	Xeyr	Bəli

10 Praktiki Təvsiyələr

10.1 Hansı Rejimi Seçməli?

Tətbiq sahəsindən asılı olaraq doğru rejimin seçilməsi sistemin təhlükəsizliyi üçün həlledicidir:

- **Ümumi məqsədli şifrəlmə:** Əgər yalnız məxfilik kifayətdirsə, **CBC** və ya **CTR** istifadə oluna bilər.
- **Autentifikasiyalı Şifrəlmə (AEAD):** Müasir sistemlər üçün **GCM** (yüksək performanslı) və ya **CCM** (resursları məhdud və ya patentsiz sistemlər üçün) təvsiyə olunur.
- **Disk Şifrəlməsi:** Yaddaş qurğularının (HDD/SSD) qorunması üçün IEEE 1619 standartı olan **XTS** rejimi seçilməlidir.
- **Rabitə Protokolları:** TLS 1.3 və IPsec kimi müasir protokollarda standart olaraq **GCM** istifadə edilir.

ECB-dən Qətiyyən Çəkinin!

ECB rejimi heç vaxt real sistemlərdə istifadə edilməməlidir. O, məlumatdakı statistik naxışları gizlətmir və bu, şifrəli mətndən açıq mətn haqqında ciddi məlumatların sızmasına səbəb olur.

10.2 IV və Nonce İdarəedilməsi

İlkin vektor (IV) və ya *nonce* (bir dəfə istifadə olunan ədəd) rejimlərin təhlükəsizlik zəmanəti üçün kritikdir:

- **CBC, CFB, OFB:** IV mütləq təsadüfi olmalı və eyni açarla heç vaxt təkrar istifadə edilməməlidir.
- **CTR və GCM:** Nonce-un bir dəfə də olsa təkrar istifadəsi **"Two-Time Pad"** hücumuna yol açır və bütün məxfiliyi dərhal yox edir.
- **GCM-SIV:** Nonce-un yanlış istifadəsinə (*nonce-misuse*) qarşı davamlıdır, lakin adi GCM-dən daha yavaş işləyir.

Nonce-un Təkrarı Fəsadları

Nonce (Bir dəfə istifadə edilən ədəd - Number used ONCE) — yalnız bir dəfə istifadə edilməlidir. Təkrar halında:

- **CTR və GCM-də:** Eyni açar axını (keystream) yaranır, bu isə hücumçuya şifrəli mətnləri XOR edərək açıq mətnləri bərpa etməyə imkan verir.
- **CBC-də:** Eyni IV və eyni başlanğıc blokları məlumatın prefiksləri haqqında sızıntı yaradır.

11 Praktiki Tapşırıqlar

11.1 Tapşırıq 1: ECB Problemi (Vizual Analiz)

Verilmiş bir təsviri (məsələn, .bmp formatında) ECB rejimində şifrəyin.

- **Sual:** Şifrələnmiş şəkildə orijinal təsvirin konturları niyə hələ də görünür?
- **Müşahidə:** ECB eyni açıq mətn bloklarını eyni şifrəli bloklara çevirdiyi üçün məlumatın statistik naxışlarını gizlədə bilmir (Dworkin, 2001; Paar and Pelzl, 2010).

11.2 Tapşırıq 2: CBC Şifrələmənin Addımları

$P = [0x53, 0x41, 0x4C, 0x41, 0x4D]$ mesajını aşağıdakı parametrlərlə CBC rejimində şifrəyin:

- **Blok şifrə funksiyası:** $E_K(X) = X \oplus K$
- **İlkin Vektor (IV):** $0x12$
- **Açar (K):** $0x34$
- **Tapşırıq:** İlk iki blok (C_1 və C_2) üçün şifrələmə prosesini düsturla ($C_i = E_K(P_i \oplus C_{i-1})$) göstərin.

11.3 Tapşırıq 3: CTR Rejimində Sayğacın Generasiyası

CTR rejimində sayğac dəyərlərinin təkrarlanmaması kritikdir (Dworkin, 2001).

- **IV (96-bit Nonce):** $0x0123456789ABCDEF01234567$
- **Tapşırıq:** İlk 5 blok üçün 128-bitlik sayğac dəyərlərini ($CTR_1, \dots, CTR_5$) artan sıra ilə yazın.

11.4 Tapşırıq 4: GCM və Əlaqəli Verilənlər (AD)

GCM rejimində **Associated Data (AD)** şifrlənmir, lakin autentifikasiya olunur (Dworkin, 2007).

- **Nümunə:** Bir HTTP paketi düşünün. Paket başlığı (Header) açıq qalmalıdır ki, marşrutlayıcılar onu oxuya bilsin, lakin header dəyişdirilməməlidir.
- **Sual:** Niyə biz AD-ni şifrləmirik, lakin təq hesablamasına (GHASH) daxil edirik?

11.5 Tapşırıq 5: XTS Tweak Hesablanması

Sektor nömrəsi $S = 42$ olan disk sektoru üçün XTS tweak dəyərini analiz edin (Dworkin, 2010).

- **Düstur:** $T_i = E_{K_2}(S) \otimes \alpha^{i-1}$
- **Sual:** Əgər eyni sektor daxilində 10-cu bloku şifrləyirsinizsə, generator elementin (α) hansı qüvvətindən istifadə edəcəksiniz?

11.6 Tapşırıq 6: Python-da Rejimlərin Implementasiyası

```

1 # əSad xor_cipher ııfunksiyasın block_cipher kimi əistifad əed
   əbilrsiniz
2 def cbc_encrypt(plaintext, iv, key):
3     cipher_text = []
4     prev_cipher = iv
5     for block in plaintext:
6         # P_i XOR C_{i-1}
7         mixed = block ^ prev_cipher
8         # E_K(mixed)
9         encrypted = mixed ^ key
10        cipher_text.append(encrypted)
11        prev_cipher = encrypted
12    return cipher_text

```

Listing 1: Blok şifrə rejimlərinin şablonu

11.7 Tapşırıq 7: Padding Oracle Hücumu Simulyasiyası

Padding oracle hücumu deşifrləmə zamanı yaranan padding xətlərindən istifadə edir (Jager and Somorovsky, 2011; Rogaway, 2011).

- **Ssenari:** Bir server "Valid Padding" üçün HTTP 200, "Invalid Padding" üçün HTTP 500 qaytarır.

- **Tapşırıq:** Hücümçunun bu məlumatdan istifadə edərək sonuncu baytı necə bərpa edə biləcəyini addım-addım təsvir edin.

Əlavə Oxu Materialları

Mövzunu daha dərinlən araşdırmaq üçün bu rəsmi standartlara müraciət edin:

- **NIST SP 800-38A:** CBC, CTR, ECB, CFB, OFB standartları.
- **NIST SP 800-38D:** GCM rejimi haqqında ətraflı.
- **NIST SP 800-38E:** XTS disk şifrələmə standartı.
- **Phillip Rogaway (2011):** Blok şifrlərin müasir qiymətləndirilməsi.
- **Paar & Pelzl (2010):** "Understanding Cryptography" kitabının 4-cü fəslı.

12 Nəticə

Bu mühazirədə blok şifrlərin müxtəlif iş rejimlərini və onların tətbiq sahələrini öyrəndik:

- **ECB:** Ən sadə rejimdir, lakin eyni bloklar üçün eyni şifrəli mətn yaratdığına görə təhlükəsiz hesab edilmir.
- **CBC:** Ən geniş yayılmış rejimlərdən biridir; hər blokun şifrələnməsi əvvəlki blokdan asılıdır və IV tələb edir.
- **CFB:** Blok şifrəni axın şifrəsi kimi istifadə etməyə imkan verir və özünü məhdud səviyyədə sinxronizasiya edə bilər.
- **OFB:** Axın şifrəsi mexanizmi ilə işləyir; xəta yayılmır, lakin dəqiq sinxronizasiya tələb edir.
- **CTR:** Blokları tam paralel şəkildə emal edir, təsadüfi giriş imkanı verir və çox yüksək sürət təmin edir.
- **GCM:** Həm məxfiliyi, həm də autentifikasiyanı təmin edən (AEAD) rejimdir və TLS 1.3-də standart kimi qəbul olunub.
- **CCM:** AEAD rejiminin digər bir növüdür və əsasən WPA2 (Wi-Fi) təhlükəsizlik standartında istifadə olunur.
- **XTS:** Saxlama qurğularının (disk) şifrələnməsi üçün nəzərdə tutulmuş IEEE standartıdır.

İş rejimlərinin seçimi konkret tətbiq sahəsindən və təhlükəsizlik tələblərindən asılıdır:

- Ümumi məqsədli şifrələmə və proqram təminatı üçün **CBC** və ya **CTR** rejimləri üstünlük təşkil edir.
- Verilənlərin həm gizliliyi, həm də tamlığı (autentifikasiyası) tələb olunduqda **GCM** və ya **CCM** rejimləri seçilməlidir.
- Disk və yaddaş qurğularının şifrələnməsi üçün **XTS** rejimi ən optimal seçimdir.

Növbəti müəhazirə

Həftə 12: Həş funksiyalarına giriş, xassələri və kriptografik tətbiqləri.

13 Praktiki Tapşırıqlar: Model Cavablar

13.1 Cavab 1: ECB Problemi

ECB rejimində şifrlənmiş şəkildə konturların görünməsi aşağıdakı səbəblərlə izah olunur:

- ECB eyni açıq mətn bloklarını eyni şifrəli mətn bloklarına çevirir.
- Şəkildəki eyni rəngli sahələr (məsələn, fon və ya geniş rəng blokları) eyni bayt ardıcılıqlarından ibarətdir.
- Şifrləmədən sonra da bu bloklar öz aralarındakı naxışları qoruyub saxladığı üçün məlumatın statistik strukturu gizlədilmir.

13.2 Cavab 2: CBC Şifrləmə Prosesi

Verilənlər: $P_1 = 0x53$, $P_2 = 0x41$, $IV = 0x12$, $K = 0x34$, $E_K(X) = X \oplus K$.

1. Blok 1:

- Giriş: $X_1 = P_1 \oplus IV = 0x53 \oplus 0x12 = 0x41$.
- Çıxış: $C_1 = E_K(0x41) = 0x41 \oplus 0x34 = \mathbf{0x75}$.

2. Blok 2:

- Giriş: $X_2 = P_2 \oplus C_1 = 0x41 \oplus 0x75 = 0x34$.
- Çıxış: $C_2 = E_K(0x34) = 0x34 \oplus 0x34 = \mathbf{0x00}$.

13.3 Cavab 3: CTR Sayğac Dəyərləri

Sayğac blokları adətən Nonce (IV) və artan sayğac hissəsinin birləşməsindən (konkatenasiya) ibarətdir. 5 blok üçün 128-bitlik dəyərlər:

- CTR₁: 0123456789ABCDEF0000000000000001
- CTR₂: 0123456789ABCDEF0000000000000002
- CTR₃: 0123456789ABCDEF0000000000000003
- CTR₄: 0123456789ABCDEF0000000000000004
- CTR₅: 0123456789ABCDEF0000000000000005

13.4 Cavab 4: GCM-də AD-nin (Əlaqəli Verilənlər) Rolu

GCM-də Associated Data (AD) şifrlənmir, lakin tamlığı qorunur.

- **Nümunə:** Şəbəkə paketinin başlığı (Header) marşrutlaşdırma üçün açıq qalmalıdır.
- **Rolu:** AD verilənləri GHASH funksiyasına daxil edilərək autentifikasiya teqinə (T) təsir edir. Əgər hücumçu başlığı dəyişdirsə, deşifrləmə zamanı təq uyğun gəlməyəcək və mesaj rədd ediləcək.

13.5 Cavab 5: XTS Tweak Hesablanması

XTS rejimində hər blok üçün tweak aşağıdakı qaydada hesablanır:

- Düstur: $T_i = E_{K_2}(S) \otimes \alpha^{i-1}$.
- Sektor daxilində 10-cu blok üçün $i = 10$ olduğu üçün, generator elementin **9-cu qüvvəti** (α^9) istifadə edilir.

13.6 Cavab 7: Padding Oracle Hücumu

Hücumun iş prinsipi serverin qaytardığı padding xətlərinə əsaslanır:

1. Hücumçu şifrəli blokun son baytlarını dəyişdirərək serverə göndərir.
2. Serverin cavabına əsasən (200 OK və ya 500 Error), padding-in düzgün olub-olmadığını müəyyən edir.
3. Məlum padding standartı (məs. PKCS#7) və XOR əməliyyatı vasitəsilə açıq mətnin orijinal baytlarını bir-bir bərpa edir.

References

- M. Bellare, A. Desai, E. Jokipii, and P. Rogaway. A concrete security treatment of symmetric encryption: Analysis of the des modes of operation. In *Proceedings of the 38th Annual Symposium on Foundations of Computer Science*, pages 394–403. IEEE, 1997.
- M. Dworkin. Recommendation for block cipher modes of operation. Technical Report SP 800-38A, National Institute of Standards and Technology, 2001.
- M. Dworkin. Recommendation for block cipher modes of operation: The ccm mode for authentication and confidentiality. Technical Report SP 800-38C, National Institute of Standards and Technology, Gaithersburg, 2004.
- M. Dworkin. Recommendation for block cipher modes of operation: Galois/counter mode (gcm) and gmac. Technical Report SP 800-38D, National Institute of Standards and Technology, Gaithersburg, 2007.
- M. Dworkin. Recommendation for block cipher modes of operation: The xts-aes mode for confidentiality on storage devices. Technical Report SP 800-38E, National Institute of Standards and Technology, Gaithersburg, 2010.
- T. Jager and J. Somorovsky. Breaking xml encryption: typically with xml schemas. In *Proceedings of the 18th ACM conference on Computer and communications security*, pages 313–322, 2011.
- C. Paar and J. Pelzl. *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer, Berlin, 2010. ISBN: 978-3642041006.
- P. Rogaway. Evaluation of some blockcipher modes of operation. *Cryptography Research Group Report*, 2011. University of California, Davis.
- P. Rogaway, M. Bellare, and J. Black. Ocb: A block-cipher mode of operation for efficient authenticated encryption. In *Advances in Cryptology — CRYPTO 2001*, pages 196–217. Springer, 2001.
- W. Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7 edition, 2017.